Yazılım Kalitesi: Deneyim Borcu

ÖFY

November 2026

Özet

Güvenlik ve kalite, kullanıcının bakış açısından deneyimin (*experience*) alt bileşenleridir; kullanıcı bunları ayrı nitelikler olarak değil, tek bir bütünün parçası olarak yaşar. Ancak güvenliğin ve kalitenin önemli bir kısmı hiçbir kullanıcının doğrudan deneyimlemediği yerlerde bulunur; bu kısım deneyimi yaşayan aktörler genişletildiğinde (kullanıcı, geliştirici, şirket ve toplum) yeniden görünür hâle gelir. Bir şeyin nasıl hissettirdiği ile gerçekte ne olduğu birbirinden bağımsız olabildiği için, deneyimin yanında üç ayrı katman tutulmalıdır: doğruluk, sonuç ve bu ikisini deneyime bağlayan doğrulama. Akıcılık (*fluency*), eskiden doğrulukla birlikte gelen bir işaret olduğu için insanlarda örtük bir güven sinyali üretir; dil modelleri bu bağı kopararak akıcılığı bilgiden bağımsız biçimde üretilebilir kılmıştır. Alıcının kaliteyi doğrulayamadığı piyasalarda görünüşe yapılan yatırım kısa ve orta vadede ödüllendirilir; bu durum, deneyimin altındaki gerçeğin taşıyabileceğinden fazla güven ürettiği ve riski farkında olmadan kullanıcının üstlendiği bir *deneyim borcu* doğurur. Bir ürünün ne kadar derin üretilmesi gerektiği görünen yüzeye göre değil, hatanın bedeline, bedeli kimin ödediğine, geri alınabilirliğe ve kullanıcının doğrulama imkânına göre belirlenir. Duygu farkındalığı yanılgıları gidermeye yetmediği için doğrulama, kişinin o anki hissine bağlı olmayan dış yapılarla (kontrol listeleri, başka gözler, ölçüm, ortam tasarımı) kurulmalıdır. Yıkıcı ya da radikal yenilik büyük ölçüde deneme maliyetinin düşürülmesine ve ucuz hayal alanı ile pahalı gerçek alan arasında sağlam bir doğrulama köprüsü kurulabilmesine bağlıdır.

Giriş

Yazılım ve ürün tasarımında güvenlik, kalite ve kullanıcı deneyimi çoğunlukla ayrı disiplinler olarak ele alınır. Yaygın bir kabule göre güvenlik ile kullanılabilirlik birbirinin karşıtıdır: güvenlik arttıkça sürtünme artar, deneyim kötüleşir. Bu not, söz konusu ayrımın kullanıcı açısından yapay olduğunu, ancak bütünüyle ortadan kaldırıldığında da tehlikeli bir sonuca yol açtığını savunur.

Notta kullanılan merkezî terimler şunlardır:

- **Deneyim**: Bir ürünün, sistemin ya da durumun ona maruz kalan kişiye nasıl göründüğü ve nasıl hissettirdiği; kolaylık, hız, güven hissi ve memnuniyet gibi algılanan niteliklerin bütünü.
- **Doğruluk**: Bir şeyin gerçekte ne olduğu; algılanış biçiminden bağımsız olarak doğru, sağlam ya da güvenli olup olmadığı.
- **Sonuç**: Bir şeyin zaman içinde ve kullanımda yol açtığı etki; o an hissedilmese bile gerçekleşen kazanç ya da zarar.
- **Doğrulama**: Görüneni gerçekle karşılaştıran işlem; kişinin hissine değil, nesnenin kendisine bakan sınama.

Bu dört kavram birbirinden ayrı tutulduğunda üç soru netleşir: Güvenlik ve kalite deneyimin neresinde durur? Deneyim ile gerçek arasındaki boşluk neden tehlikelidir? Bu boşluk hangi araçlarla kapatılır? Not ayrıca bu çerçeveyi bir güvenlik olayına, piyasa ekonomisine, mühendislik standartlarına, kişisel çalışma düzenine ve yaratıcılık süreçlerine uygular.

Notun kapsamı kavramsal bir çerçeveyle sınırlıdır. Standartların ve yasal düzenlemelerin ayrıntılı uygulama gereklilikleri, sertifikasyon süreçleri ve belirli araçların teknik kurulumu kapsam dışıdır.

Deneyim, Güvenlik ve Kalite

Güvenliğin Deneyimdeki Yeri

Bir sohbet uygulamasında kullanıcının rahat konuşabilmesinin temel koşullarından biri, uygulamaya güvenmesidir. Kullanıcı güvenliği teknik bir özellik olarak değil, bir his olarak yaşar. Bu his birkaç somut beklentiden oluşur:

- Mesajların üçüncü kişilerce okunmayacağı.
- Hesabın kolayca ele geçirilemeyeceği.
- Yanlışlıkla paylaşılan bir şeyin silinebileceği ya da geri alınabileceği.
- Kimin neyi görebildiğinin açıkça anlaşılabileceği.

Güvenlik başarısız olduğunda deneyim de başarısız olur. Sızan bir mesaj ya da çalınan bir hesap, tasarımın diğer bütün niteliklerinden bağımsız olarak güveni bitirebilir ve bu güven kolay geri kazanılmaz.

Buna karşılık aşırı zahmetli güvenlik de deneyimi bozar. Her girişte uzun doğrulamalar, sık şifre istemleri ya da karmaşık izin ekranları kullanıcıyı yorar ve güvenlik önlemlerini atlatmaya iter. İyi tasarım bu nedenle güvenliği mümkün olduğunca görünmez kılar. Uçtan uca şifreleme (*end-to-end encryption*) bunun tipik örneğidir: arka planda çalışır ve kullanıcı herhangi bir işlem yapmadan korunur.

Deneyimin Üst Kavram Olarak Ele Alınması

Kullanıcı açısından deneyim, güvenliğin yanında duran bir kavram değil, onu kapsayan üst kavramdır. Aynı ilişki kalite için de geçerlidir: uygulamanın hızlı açılması, çökmemesi ya da veri kaybetmemesi kullanıcıya "kalite" olarak değil, iyi bir deneyim olarak yansır.

Bu bakışın bir sınırı vardır. Güvenliğin ve kalitenin bir kısmı kullanıcının hiç görmediği yerlerde bulunur:

- **Güvenliğin görünmeyen tarafı**: Sunucudaki verilerin korunması, verinin üçüncü taraflara sızmaması, yasal kurallara uyum. Bunlar kullanıcı deneyimine hiç yansımayabilir, ancak önemlerinden bir şey kaybetmezler. Yalnızca deneyim üzerinden bakıldığında "kullanıcı fark etmiyorsa sorun yoktur" biçiminde tehlikeli bir sonuca varılabilir.
- **Kalitenin görünmeyen tarafı**: Kodun okunabilirliği, değiştirilebilirliği ve test edilebilirliği. Bunlar kullanıcıya doğrudan yansımaz; uzun vadede dolaylı olarak dokunur.

Kullanıcı açısından deneyim üst kavramdır; mühendislik açısından ise güvenliğin ve kalitenin deneyime yansımayan ama vazgeçilemeyen bir tarafı vardır.

Hiyerarşinin Üç Biçimi

Deneyim, güvenlik ve kalite ilişkisi üç farklı ağaç biçiminde modellenebilir. Her biri bir öncekinin eksikliğini gidermeye çalışır.

Birinci Biçim: Görünen ve Görünmeyen Dallar

İlk modelde kökte deneyim, altında güvenlik ve kalite bulunur. Her dalın kullanıcının gördüğü ve görmediği yaprakları vardır:

- Deneyim
  - Güvenlik
    - Görünen: mesaj gizliliği, hesap koruması
    - Görünmeyen: sunucu verisinin korunması, yasal uyum
  - Kalite
    - Görünen: hız, kararlılık
    - Görünmeyen: okunabilir kod, testler

Bu modelin zayıflığı, görünmeyen yaprakların ağaca belirsiz bir biçimde bağlı kalmasıdır. Ağaç tek bir aktörün, kullanıcının gözünden çizildiği için kullanıcının görmediği parçalar yerleşecek bir yer bulamaz.

İkinci Biçim: Deneyimi Yaşayan Aktörler

İkinci modelde deneyim yine köktedir, ancak altındaki ilk dallanma "kimin deneyimi" sorusuna göre yapılır:

- Deneyim
  - Kullanıcının deneyimi: mesaj gizliliği, hız, kararlılık
  - Geliştiricinin deneyimi: okunabilir kod, testler, kolay değişiklik
  - Şirketin ve toplumun deneyimi: yasal uyum, verinin korunması, itibar

Bu biçimde görünmeyen bir şey kalmaz; kullanıcının görmediği şeyi başka bir aktör yaşar. Okunabilir kodu geliştirici her gün hisseder. Veri sızıntısını kullanıcı o an fark etmeyebilir, ancak sızan verinin sahibi bunun bedelini sonradan öder.

Bu modelin de bir eksiği vardır: güvenlik ve kalite kavramları ağaçtan kaybolmuş, aktörlerin altına dağılmıştır. Oysa başlangıçtaki sezgi, bu iki kavramın deneyimin alt başlıkları olduğuydu.

Üçüncü Biçim: Birleşik Model

Üçüncü model iki fikri birleştirir. Ağacın yapısı güvenlik ve kaliteyi deneyimin alt başlıkları olarak korur; her yaprak ise onu yaşayan aktörle etiketlenir:

- Deneyim
  - Güvenlik
    - Mesaj gizliliği (kullanıcı)
    - Hesap koruması (kullanıcı)
    - Veri koruması (şirket ve toplum)
    - Yasal uyum (şirket ve toplum)
  - Kalite
    - Hız (kullanıcı)
    - Kararlılık (kullanıcı)
    - Okunabilir kod (geliştirici)
    - Testler (geliştirici)

Bu modelde her parçanın onu yaşayan bir sahibi vardır, ancak bu sahip her zaman kullanıcı değildir.

Literatürdeki Karşılıklar

Kullanılabilir Güvenlik

Kullanılabilir güvenlik (*usable security*), güvenlik önlemlerinin insanların gerçekte nasıl davrandığı dikkate alınarak tasarlanmasını inceleyen alandır. Alanın kurucu çalışmalarından biri, Whitten ve Tygar'ın PGP şifreleme yazılımının sıradan kullanıcılar tarafından doğru kullanılamadığını gösteren çalışmasıdır (Whitten ve Tygar, 1999). Alanın temel iddiası, kullanılamayan bir güvenlik önleminin pratikte koruma sağlamadığıdır; çünkü insanlar karmaşık önlemleri atlatır ya da yanlış kullanır. Bu nedenle güvenlik deneyimin içine tasarlanmalı, sonradan üzerine eklenmemelidir.

Microsoft, Secure Future Initiative adlı daha geniş güvenlik programının parçası olarak bir "Secure by Design" kullanıcı deneyimi araç seti yayımlamıştır. Şirket bu araç setini, güvenlik ihlallerinin çoğunun insan hatasından kaynaklandığı tespitine dayandırır (Microsoft Design, t.y.). Şirketin Nisan 2025 tarihli ilerleme raporuna göre araç seti 20 ürün ekibiyle denenmiş, 22.000 çalışana yayılmış ve herkese açık bir sürümü yayımlanmıştır (Microsoft, 2025).

Kullanımda Kalite

ISO/IEC 25010 standardı kaliteyi iki modele ayırır: ürün kalitesi ve kullanımda kalite (*quality in use*). Kullanımda kalite, ürünün belirli bir kullanıcı tarafından belirli bir bağlamda kullanıldığında ortaya çıkan kalitedir. Standardın 2011 sürümünde bu model şu niteliklerden oluşur (ISO/IEC, 2011):

- Etkinlik: işin doğru ve eksiksiz yapılması.
- Verimlilik: işin harcanan kaynağa oranla yapılabilmesi.
- Memnuniyet: kullanışlılık, güven (*trust*), haz ve konfor alt nitelikleriyle birlikte.
- Riskten özgürlük: ekonomik, sağlık ve güvenlik ile çevresel risklerin azaltılması.
- Bağlam kapsamı: ürünün farklı kullanım bağlamlarında da bu nitelikleri koruması.

Bu konuda yaygın üç yanlışlık vardır. Birincisi, kullanımda kalite kavramı ISO 9241-11'e değil ISO/IEC 25010'a aittir; ISO 9241-11 kullanılabilirliği etkinlik, verimlilik ve memnuniyet üzerinden tanımlar. İkincisi, güven ayrı bir nitelik değil, memnuniyetin alt niteliğidir. Üçüncüsü, riskten özgürlük yalnızca bilgi güvenliğini değil, ekonomik, sağlık ve çevresel riskleri de kapsar. Kullanımda kalite modeli 2023'te ayrı bir standart olan ISO/IEC 25019'a taşınmıştır.

Standardın en önemli yönü, ürün kalitesini ayrı tutmasıdır. Bakım kolaylığı ya da test edilebilirlik gibi nitelikler ürün kalitesine aittir ve kullanıcıya doğrudan görünmez. Dolayısıyla standardın kendisi de kalitenin tamamının kullanıcı deneyimi olmadığını kabul eder.

Anshin ve Anzen

Japoncada güvenliğe ilişkin iki ayrı kavram bulunur. *Anzen* nesnel güvenliği, *anshin* ise kişinin içinin rahat olmasını, endişeden uzak olma hissini ifade eder. İki kavram gündelik dilde sıklıkla "anzen anshin" biçiminde birlikte kullanılır. Bu ayrım, deneyim (güvenlik hissi) ile doğruluk (gerçek güvenlik) arasındaki farkın dile yerleşmiş bir karşılığıdır.

Doğruluk, Akıcılık ve Güven Sinyali

Doğruluğun Deneyimdeki Yeri

Doğru olmayan bir çıktı, ne kadar hızlı ve özenli sunulursa sunulsun kötü bir deneyimdir. ISO/IEC 25010'daki kullanımda kalite modelinin ilk niteliği olan etkinlik de işin doğru ve eksiksiz yapılması anlamına gelir. Doğruluk bu nedenle deneyimin en temel bileşenlerinden biridir.

Doğrulama, güvenlikle aynı yapısal özelliği paylaşır: iyi yapıldığında görünmez. Kullanıcı yalnızca bedelini görür (cevabın daha geç gelmesi, araya bir arama girmesi); faydasını ise göremez, çünkü fayda yanlış bir şeyin gerçekleşmemesidir.

Dil Modellerinin Kendinden Emin Hatası

Sohbet tabanlı yapay zekâ araçlarında kötü bir cevap çoğunlukla kendini belli etmez. Kendinden emin ve akıcı biçimde yazılmış yanlış bir bilgi, kullanıcı tarafından doğru kabul edilip kullanılabilir. Bu durumun birkaç kaynağı vardır:

1. **Akıcılık doğruluktan önce öğrenilir.** Bir dil modeli eğitim sırasında bir metinden sonra hangi kelimenin geleceğini tahmin etmeyi öğrenir. Bu, çok iyi cümle kurma becerisi kazandırır; ancak iyi kurulmuş bir cümle ile doğru bir cümle aynı şey değildir.

2. **Güvenilir bir "bilmiyorum" sinyali yoktur.** Model, bir konuyu gerçekten bildiği durumla yalnızca tahmin yürüttüğü durumu her zaman ayırt edemez; iki durumda da bir sonraki kelimeyi üretir.

3. **Ton sabittir.** Model emin olduğunda da tahmin yürüttüğünde de aynı düzgün üslupla yazar. İnsan konuşmasındaki duraksama ve tereddüt işaretleri kendiliğinden ortaya çıkmaz.

4. **Değerlendirme tahmin etmeyi ödüllendirir.** OpenAI araştırmacılarının bir çalışmasına göre modellerin çoğu testte yalnızca doğru cevap sayısıyla puanlanması, "bilmiyorum" demeyi sıfır puanla, tahmin etmeyi ise zaman zaman puanla sonuçlandırır; bu da tahmin etmeyi ödüllendiren bir eğitim baskısı yaratır (Kalai vd., 2025).

5. **İnsanlar akıcı metne daha çok güvenir.** Bu, modelin değil insan algısının bir özelliğidir ve ayrı bir başlık altında ele alınır.

Sessiz Hata ve Gürültülü Hata

Çöken bir uygulama hatasını kendisi bildirir. Yanlış ama akıcı bir cevap ise hatasını gizler; hata, çıktı bir yerde kullanılıp sonucu görülene kadar ortaya çıkmaz, bazen hiç çıkmaz. Bu nedenle sessiz hata, gürültülü hatadan daha tehlikelidir. Mühendislikteki "erken ve yüksek sesle hata ver" (*fail fast*) ilkesi bu gözleme dayanır.

Akıcılık Sezgisi

Akıcılık sezgisi (*fluency heuristic*), bir bilginin işlenmesinin kolay olmasının, o bilginin doğru olduğu yönünde bir yargıya dönüşmesidir. Okunması kolay biçimde sunulan önermelerin daha doğru bulunduğu deneysel olarak gösterilmiştir (Reber ve Schwarz, 1999). Aynı ifadenin tekrarlandıkça daha inandırıcı hâle gelmesi de, yanıltıcı doğruluk etkisi (*illusory truth effect*) adıyla bilinen bağlantılı bir olgudur (Hasher, Goldstein ve Toppino, 1977).

Bu süreç bilinçli değildir. Kişi "bu metin akıcı, o hâlde doğrudur" diye akıl yürütmez; yalnızca "bu doğru gibi geliyor" hissini yaşar. Kolaylık hissi doğruluk hissine karışır. Akıcı bir şeyin gizlice güven sinyali vermesi bu anlama gelir.

Beynin bu kısayolu kullanmasının bir gerekçesi vardır: kısayol çoğu zaman işe yarar. Tanıdık ve kolay anlaşılan bilgiler çoğunlukla daha sık karşılaşılan, dolayısıyla daha sık doğrulanmış bilgilerdir. Bir konuyu iyi bilen biri de genellikle akıcı konuşur. Akıcılık ile doğruluk arasında gerçek bir bağ bulunuyordu ve sezgi bu bağa dayanıyordu.

Sorun bu bağın kopmasıyla başlar. Eskiden bir konuda akıcı konuşabilmek için o konuyu bilmek gerekiyordu; akıcılığın bir bedeli vardı. Dil modelleri bu bedeli sıfırlamış, akıcılığı bilgiden bağımsız olarak her konuda üretilebilir kılmıştır. Sezgi ise hâlâ eski koşullara göre çalışır. Akıcılık yalan söylemez; yalnızca eskiden güvenilir olan bir işaret artık eskisi kadar bilgi taşımaz.

Soyut İlkeler

Yukarıdaki gözlemler dil modellerinden bağımsız biçimde şu ilkelere indirgenebilir:

1. **Biçim ile içerik ayrıdır.** Bir şeyin nasıl göründüğü ile ne olduğu birbirinden bağımsız olabilir; düzgün biçim doğru içeriği garanti etmez.

2. **Güven sinyali güvenilirlikten kopabilir.** İnsanlar güvenilirliği doğrudan göremez, ona işaret eden sinyallere bakar. Bu sinyaller asıl nitelikten ayrı üretilebildiği anda yanıltıcı olur.

3. **Bir sistem neyle ödüllendirilirse onu öğrenir.** Görünüş ödüllendirilirse görünüş gelişir; doğruluk ölçülmüyorsa kendiliğinden gelişmez. Bu, bir ölçütün hedef hâline geldiğinde iyi bir ölçüt olmaktan çıktığını söyleyen Goodhart yasasının bir biçimidir (Goodhart, 1975).

4. **Sessiz hata gürültülü hatadan tehlikelidir.** Kendini belli eden hata düzeltilir, kendini gizleyen hata birikir ve yayılır.

5. **Belirsizliği göstermek bir dürüstlük biçimidir.** Emin olmadığı yerde bunu belirten bir sistem, daha az etkileyici görünse de her şeyi aynı tonla söyleyen bir sistemden daha güvenilirdir.

Bu ilkeler tek bir önermede birleştirilebilir:

> Bir şey doğru olmadan doğru görünebiliyorsa, güven görünüşe değil doğrulamaya dayanmalıdır.

Aynı yapı kendinden emin konuşan ama yanılan bir uzmanda, parlak ama içi boş bir raporda ya da hiçbir uyarı vermeden yanlış veri yazan bir yazılımda da bulunur.

Deneyim ile Gerçek Arasındaki Ayrım

Her Şey Deneyimin Alt Parçası mıdır

Dünya hakkında bilinen her şey bir biçimde deneyim yoluyla edinilir. Felsefede uzun bir gelenek bu gözlemden yola çıkar: Berkeley var olmayı algılanmakla özdeşleştirir, Husserl'in fenomenolojisi şeyleri bilince nasıl göründükleri üzerinden inceler. Ancak burada iki ayrı iddia bulunur:

- **Epistemik iddia**: Her şey deneyim yoluyla bilinir. Bu iddia büyük ölçüde savunulabilir.
- **Ontolojik iddia**: Her şey deneyimdir. Bu iddia çok daha tartışmalıdır.

Ontolojik iddianın sorunu, akıcılık tartışmasıyla çelişmesidir. Bir cevabın doğru gibi hissettirip yanlış olabildiğini söyleyebilmek için "doğru hissetmek" ile "doğru olmak" arasında bir fark bulunması gerekir. Her şey deneyimse bu fark ortadan kalkar; doğru gibi hissettiren her şey doğru sayılır ve yanılgıyı fark etmenin yolu kalmaz. Güvenlikte de aynı durum geçerlidir: önlenen bir saldırıyı kimse deneyimlemez, ancak gerçekleşmiş bir şeydir; bir zarar engellenmiştir.

Kavramsal bir sorun da vardır. Her şeyi içine alan bir kavram hiçbir şeyi ayırt etmez. Deneyimi bir ağacın kökü yapmak, bazı şeylerin ağacın içinde, bazılarının dışında kalabilmesi sayesinde açıklayıcı olur.

Bu ayrım basit bir örnekle gösterilebilir. Çok iyi yapılmış sahte bir banknot gözle ve dokunuşla gerçek gibi algılanır; deneyim açısından gerçek bir paradır, ancak sahtedir. "Her şey deneyimdir" denirse bu banknotun gerçek para sayılması gerekir. Deneyim dünyaya açılan tek kapı olabilir, ancak kapı ile kapının ardındaki şey aynı değildir. Aradaki boşluğu korumak, yanılabilirliği ve düzeltilebilirliği kabul etmenin koşuludur.

Deneyimden Ayrılması Gerekenler

Deneyimden ayrı tutulması gerekenler basit bir ölçütle belirlenir: kişi hissetmese de doğru ya da yanlış olabilen her şey. Bu ölçüt üç katman verir. Deneyimle birlikte dört katmanlı bir model ortaya çıkar:

Katman	Sorduğu soru	Sohbet cevabındaki karşılığı
Deneyim	Nasıl görünüyor, nasıl hissettiriyor?	Cevap akıcı okunuyor, güven veriyor.
Doğruluk	Gerçekten doğru mu?	İçindeki bilgi gerçekte doğru mu?
Sonuç	Kullanılınca ne olur?	Bilgi bir yerde kullanıldığında ne oluyor?
Doğrulama	Görünen, gerçekle örtüşüyor mu?	Kaynağa bakmak, arama yapmak.

Modelin yapısı şöyledir: deneyim üst katmandadır; doğruluk ve sonuç gerçek katmanını oluşturur; doğrulama ise ikisinin arasında köprü kurar. Üst katman ile alt katman kendiliğinden birbirini tutmaz. Doğrulama çıkarıldığında, üstteki

his ile alttaki gerçek arasında hiçbir bağ kalmaz. İyi bir sistemde dört katman birbirini tutar: deneyim güven verir, doğrulama bu güvenin hak edilmiş olduğunu gösterir.

Modelin Farklı Alanlarda Görünümü

Aşk

Bir kişinin "seni seviyorum" demesi ve güzel sözler söylemesi deneyim katmanıdır. O kişinin gerçekten sevip sevmediği doğruluktur; sözlerin güzelliğinden bağımsızdır. Zor bir gün geldiğinde kişinin kalıp kalmadığı sonuçtur. Söylenenle yapılanın zaman içinde tutup tutmadığı ise doğrulamadır. Akıcılıkla paralellik açıktır: her şeyi doğru zamanda doğru kelimeyle söyleyen biri, sevgisi gerçek olmasa da çok sevgi dolu görünebilir. Güzel söz sevginin kanıtı değil, işaretidir.

Aşkın sohbet cevabından bir farkı vardır. Sohbette deneyim bir araçtır, asıl önemli olan doğruluktur. Aşkta ise his işin kendisidir ve yaşanması zaten değerlidir. Yine de karşıdaki kişinin hissi, yaşanan histen ayrı bir şeydir. Aşkta doğrulamanın aracı bir kaynak ya da arama değil, zamanın kendisidir.

Fabrika Hattı

Otomobil parçası üreten bir hatta parçanın parlak ve düzgün görünmesi ve kontrol ekranındaki göstergenin yeşil yanması deneyim katmanıdır. Parçanın ölçülere uygun olup olmadığı, içinde gözle görülmeyen bir çatlak bulunup bulunmadığı doğruluktur. Parçanın bir araca takılıp aylar sonra yolda kırılması ve binlerce aracın geri çağrılması sonuçtur. Ölçüm, röntgen ve test tezgâhında zorlama ise doğrulamadır.

Parlak yüzey, akıcı cevabın karşılığıdır: güven verir ama içini göstermez. Yeşil gösterge de benzer bir risk taşır; sensör bozuksa ekran "her şey yolunda" gösterir, ancak aslında ölçüm yapılmıyordur. Hat yalnızca saatte çıkan parça sayısıyla ölçülürse herkes hıza odaklanır; kalite ölçülmüyorsa kendiliğinden korunmaz.

Toyota üretim sistemindeki *andon* uygulaması sessiz ve gürültülü hata ayrımının üretimdeki karşılığıdır: herhangi bir işçi bir hata gördüğünde hattı durdurabilir (Ohno, 1988). Üretimin durması ilk bakışta kötü bir deneyimdir, ancak hatalı parçanın sessizce müşteriye ulaşmasından çok daha iyidir.

Diğer Alanlar

- **Sağlık**: Kendini iyi hissetmek (deneyim), gerçekten sağlıklı olmak (doğruluk), yıllar sonra ortaya çıkan hastalık (sonuç), tahlil ve kontrol muayenesi (doğrulama).
- **Öğrenme**: Bir konuyu okurken "anladım" hissi (deneyim), gerçekten öğrenmiş olmak (doğruluk), bilgiyi sınavda ya da işte kullanabilmek (sonuç), kendi kendine soru çözmek (doğrulama). Eğitim araştırmalarında tekrar

tekrar okumanın anlamış gibi hissettirdiği ama kalıcı öğrenme sağlamadığı durum yeterlilik yanılsaması (*illusion of competence*) olarak adlandırılır.

- **Haber**: İnandırıcı bir başlık (deneyim), olayın gerçekten öyle olup olmadığı (doğruluk), habere dayanarak verilen kararlar (sonuç), teyit (doğrulama).
- **Bilim**: Heyecan verici bir deney sonucu (deneyim), sonucun gerçekten doğru olup olmadığı (doğruluk), ona dayanan yeni çalışmalar (sonuç), deneyin başkalarınca tekrarlanması (doğrulama).

Dörtlü yapı bu kadar yaygındır, çünkü gerçeğe hiçbir zaman doğrudan değil, her zaman bir deneyim üzerinden ulaşılır. Platon'un mağara alegorisindeki gölgeler aynı boşluğu anlatır.

Ancak katmanların ağırlığı alandan alana değişir. Müzikte ve sanatta deneyimin kendisi amaçtır; bir şarkının ne hissettirdiği onun "doğru" olup olmadığından daha önemlidir ve doğrulamanın anlamı zayıftır. Matematikte durum tersidir: sezginin ne söylediğinden bağımsız olarak yalnızca ispat geçerlidir ve deneyim neredeyse hiç sayılmaz. Aşk bu iki ucun arasında durur.

Felsefi ve Kuramsal Arka Plan

Kavramların Felsefedeki Geçmişi

Dört katmanın her biri felsefede ayrı ayrı ve uzun süre tartışılmıştır.

- **Deneyim**: Deneycilik (*empiricism*) geleneği, özellikle Locke ve Hume, bütün bilginin deneyimden geldiğini savunur. Husserl ve Merleau-Ponty'nin fenomenolojisi şeyleri bilince görünüş biçimleri üzerinden inceler.
- **Görünüş ile gerçek arasındaki boşluk**: Platon'un mağara alegorisi bu boşluğun en eski anlatımlarından biridir. Kant, şeylerin bize göründüğü hâli (fenomen) ile kendinde oldukları hâli (numen) ayırır ve ikincisine hiçbir zaman tam ulaşılamayacağını savunur (Kant, 1781).
- **Doğruluk**: Uygunluk kuramı (*correspondence theory*) bir önermenin gerçekle örtüştüğünde doğru olduğunu söyler ve Aristoteles'e kadar uzanır. Tutarlılık kuramı (*coherence theory*) ise bir önermenin diğer inançlarla çelişmediğinde doğru olduğunu söyler.
- **Sonuç**: Pragmatizm, bir fikrin anlamını ve değerini pratik sonuçlarıyla ilişkilendirir. Peirce bir kavramın anlamını onun pratik sonuçlarıyla tanımlar (Peirce, 1878); William James bir fikrin "nakit değeri"nden söz eder (James, 1907).
- **Doğrulama**: Viyana Çevresi'nin mantıkçı pozitivizmi, bir önermenin ancak doğrulanabildiğinde anlamlı olduğunu savunur. Popper buna karşı çıkar: hiçbir genel önerme kesin olarak doğrulanamaz, yalnızca yanlışlanmaya çalışılabilir; bilimsel bir iddia yanlışlanabilir olmalıdır (Popper, 1959).

Akıcılık tartışmasına en yakın üç felsefi tartışma şunlardır:

- **Descartes**: Açık ve seçik biçimde kavranan fikirlerin doğru olduğunu öne sürer (Descartes, 1641); yani kesinlik hissini doğruluk ölçütü yapar. Sonraki eleştiriler, his ile doğruluğun aynı şey olmadığını gösterir. Bu, akıcılık sorununun felsefedeki eski bir biçimidir.
- **Gettier**: Bir inancın hem doğru hem gerekçeli olup yine de bilgi sayılmayabileceğini gösterir; çünkü doğruluk bazen şans eseri tutar (Gettier, 1963). Deneyim ile doğruluk tesadüfen örtüşebilir, ancak bu doğrulama yapılmış olduğu anlamına gelmez.
- **Tanıklık epistemolojisi** (*epistemology of testimony*): Başkalarının söylediğine ne zaman güvenilmesi gerektiğini inceler. Bir yapay zekâ cevabına güvenmek de bu sorunun güncel bir örneğidir.

Dörtlü Yapıya En Yakın Çerçeveler

Deneyim, doğruluk, sonuç ve doğrulama kelimeleriyle olmasa da aynı yapıyı kuran düşünürler ve alanlar mevcuttur:

- **John Dewey**: Dört öğeyi tek bir araştırma (*inquiry*) sürecinde birleştirir. Bilgi deneyimle başlar, bir fikir ortaya atılır ve sonuçlarına bakılarak sınanır. Sınamadan geçen fikir için "doğru" yerine "gerekçeli olarak savunulabilir" (*warranted assertibility*) ifadesini kullanır (Dewey, 1938).
- **Onora O'Neill**: Güven ile güvenilirliği ayırır. Güven bir tutumdur; güvenilirlik ise karşı tarafın gerçek özelliğidir. Ona göre sorun insanlara daha çok güvenmelerini söylemek değil, güvenin güvenilir olana yönelmesini sağlamaktır; bunun için güvenilirliğin dışarıdan değerlendirilebilir olması gerekir (O'Neill, 2002). Bu ayrım, deneyim katmanı (güven hissi) ile doğruluk katmanı (güvenilirlik) arasındaki boşluğun doğrudan karşılığıdır.
- **Lee ve See**: Otomasyona duyulan güvenin, sistemin gerçek performansıyla uyumlu olması gerektiğini savunur ve buna ayarlı güven (*calibrated trust*) adını verir. Gereğinden fazla güven de gereğinden az güven de sorundur (Lee ve See, 2004).
- **Yazılım mühendisliğinde doğrulama ve geçerleme**: Boehm'in ayrımına göre doğrulama (*verification*) "ürünü doğru mu yapıyoruz", geçerleme (*validation*) ise "doğru ürünü mü yapıyoruz" sorusunu yanıtlar (Boehm, 1981). Kullanıcı deneyimi bu ikisine eklendiğinde dörtlü yapıya yaklaşılır.

Fikrin parçaları yeni değildir: Dewey süreci, O'Neill güven boyutunu, Lee ve See ölçülebilir hâlini, yazılım mühendisliği pratik tarafını ele almıştır. Bu notta yapılan, bunları ürün ve sistem tasarımında kullanılabilecek tek ve basit bir şemada birleştirmektir.

Vaka: Railway Güvenlik Olayı

Olay

Railway, uygulama dağıtımı (*deployment*) için kullanılan bir bulut platformudur ve geliştirici deneyimi (*developer experience*, DX), düşük maliyeti ve kolaylığıyla tanınır. 21 Ekim 2026'da şirket bir güvenlik olayı açıkladı. Şirketin ön raporuna göre saldırgan, build altyapısındaki bir yetki yükseltme (*privilege escalation*) açığından yararlanarak iç sistemlerin bir kısmına erişti (Railway, 2026). Olayı derleyen kaynaklara göre hedef, API anahtarları, veritabanı şifreleri ve bulut kimlik bilgileri gibi en hassas bilgilerin tutulduğu ortam değişkenleri (*environment variables*) deposuydu.

Railway olayı sınırlamak için bütün bölgelerde build ve dağıtım işlemlerini durdurdu, bütün kullanıcı oturumlarını sonlandırdı, API token'larını geçersiz kıldı ve kullanıcılardan bütün gizli bilgilerini yenilemelerini istedi. Şirketin raporuna göre çalışan servisler olay boyunca ayakta kaldı; tam API erişimi ise ertesi günün akşamı yeniden sağlandı (Railway, 2026). Kullanıcı açısından platform, yaklaşık iki gün boyunca yeni bir şey dağıtılamayan bir hâle geldi.

Modelin Uygulanması

- **Deneyim**: Geliştirici deneyimi gerçekten iyiydi. Bu his sahte değildi; gerçekten yaşanan bir şeydi.
- **Gerçek katman**: Deneyimin altında kullanıcının göremediği bir katman vardı: anahtarların nasıl saklandığı ve build sisteminin nasıl korunduğu. Bu katman iyi çalıştığı sürece hiç deneyimlenmedi.
- **Doğrulama**: Kullanıcının elinde değildi. İyi bir geliştirici deneyimine bakıp "bu ekip işini biliyor" sonucuna varmak doğaldır; ancak bu, akıcılığın güven sinyali vermesinin tam karşılığıdır. Pürüzsüz bir arayüz, arkadaki güvenliğin kanıtı değildir.

Sessiz Hata

Olayı derleyen bir zaman çizelgesine göre durum sayfası sabah saatlerinde "platform kesintisi" başlığıyla açılmış, güvenlik uyarısı ise akşam saat 22.00 civarında yayımlanmıştır; bu arada bazı kullanıcılar kötüye kullanım belirtilerini kendileri fark etmiştir (Weidner, 2026). Hata önce kendini gizlemiş, ardından bir anda ortaya çıkmıştır.

İyi Deneyimin Bir Gecede Kötüleşmesi

Deneyim tek tek olumlu anlardan birikir; güven de öyle. Ancak tek bir güvenlik olayı biriken bütün olumlu anları geriye dönük olarak sorgulatır. Hatıra "kolaydı" biçiminden "kolaydı ama anahtarlar güvende değildi" biçimine dönüşür. Kötü olay, iyi geçmişi de yeniden yorumlatır. Güven yavaş birikir, hızlı tükenir.

Olayın bir de aktör boyutu vardır. Sızan anahtarlar başka şirketlere (yapay zekâ, ödeme ve bulut sağlayıcıları) aitti. Zarar yalnızca platformu kullanan geliştiriciye değil, bu anahtarların bağlı olduğu herkese yayıldı. Birleşik ağaç modelindeki "şirket ve toplum" aktörü bu durumu karşılar.

Görünüşe Yatırımın Ekonomisi

Limon Piyasası

Akerlof, ikinci el otomobil piyasasını incelediği çalışmasında şu mekanizmayı tanımlar: alıcı bir aracın iyi mi kötü mü olduğunu ayırt edemiyorsa, ikisine de aynı fiyatı öder. Bu durumda kötü aracı satan kazanır, çünkü aracı daha ucuza elde etmiştir; iyi aracı satan ise zarar eder ve zamanla piyasadan çekilir (Akerlof, 1970). Kalitenin gözlemlenemediği piyasada görünüşe yatırım yapan ödüllendirilir.

Güvenlik bu mekanizmanın uç bir örneğidir. Bazı ürünlerin kalitesi kullanıldıktan sonra anlaşılır; bir yemeğin tadı gibi. Güvenlik ise kullanıldıktan sonra bile anlaşılamaz, çünkü iyi çalıştığı sürece görünmez. Bu nedenle müşteri çoğu zaman güvenliğe değil, güvenlik hissine ödeme yapar.

Kısa ve Orta Vadede Kazanç

Deneyim hissine yatırım yapan bir şirket kısa ve orta vadede gerçekten kazanabilir:

- Görünen niteliklere yapılan yatırım hemen geri döner: daha çok kullanıcı, daha iyi yorumlar, daha hızlı büyüme.
- Görünmeyen niteliklere yapılan yatırım yalnızca maliyet gibi görünür; hiçbir şey olmadığında "bu harcama gereksiz miydi" sorusu doğar.
- Kötü olay her zaman gerçekleşmez; gerçekleşmediğinde görünüşe yatırım yapan sürekli haklı çıkmış gibi görünür.

Kötü olay gerçekleştiğinde bile bedel her zaman şirkete düşmez. Railway olayını inceleyen bir yazı, platformun sözleşmesinde sorumluluğun 100 dolarla sınırlandırıldığını aktarır (Weidner, 2026); asıl zararı anahtarları çalınanlar üstlenir. Equifax 2017'de çok büyük bir veri sızıntısı yaşamış, ancak şirketin hisseleri birkaç yıl içinde toparlanmıştır. Bedel çoğu zaman dışsallaşır, yani başkasına yüklenir.

Uzun vadeli sonuç kesin değildir; bazı şirketler tek bir olayla biter, bazıları atlatır. Ancak risk birikir ve bir gün tek seferde ödenir.

Piyasa bu dengesizliği kendi başına çözemediği için düzenleyici müdahale ortaya çıkar. Avrupa Birliği'ndeki Genel Veri Koruma Tüzüğü (GDPR) ve Siber Dayanıklılık Yasası (*Cyber Resilience Act*, CRA) gibi düzenlemeler, görünmeyen güvenliği zorunlu ve ölçülebilir kılmaya çalışır; doğrulamayı müşterinin yerine bir başka kurum üstlenir.

Bu davranışın her zaman kötü niyetten kaynaklanmadığı da belirtilmelidir. Kısıtlı kaynakla çalışan küçük şirketler çoğu zaman önce görünen niteliklere yatırım yapmak zorundadır; aksi hâlde büyüyemezler. Sorun, bu geçici önceliğin kalıcı bir alışkanlığa dönüştüğünde başlar.

Deneyim Borcu

Teknik borç (*technical debt*) kavramı Ward Cunningham tarafından ortaya atılmıştır: bugün hızlı ilerlemek için yapılan kestirme bir borçtur, faizi zamanla birikir ve bir gün ödenir (Cunningham, 1992). Aynı mantık deneyim ile gerçek arasındaki boşluğa uygulanabilir.

Deneyim borcu, bir ürünün altındaki gerçeğin taşıyabileceğinden fazla güven üretmesiyle oluşan farktır:

- **Borç**: Deneyimin vaat ettiği ile gerçeğin karşılayabildiği arasındaki fark.
- **Faiz**: Doğrulanmamış ve görünmeyen riskin her gün birikmesi.
- **Ödeme anı**: Bir olay. Borç çoğunlukla tek seferde ödenir.

Railway olayı bu yapıya uyar: geliştirici deneyimi çok güven toplamış, ancak altındaki güvenlik bu güveni taşıyamamıştır.

Kavram, kullanıcı deneyimi alanında kullanılan UX borcu (*UX debt*) kavramıyla karıştırılmamalıdır. İkisi ters yönleri anlatır:

- **UX borcu**: Sistem çalışır ama deneyim geride kalmıştır; birikmiş kullanılabilirlik sorunlarını ifade eder.
- **Deneyim borcu**: Deneyim iyidir ama gerçek geride kalmıştır.

Karışıklığı önlemek için aynı kavram "güven borcu" ya da "deneyim-gerçek borcu" olarak da adlandırılabilir.

Deneyim borcunun teknik borçtan önemli bir farkı vardır. Teknik borcu geliştirici bilir ve çoğunlukla bilerek alır. Deneyim borcunda ise borcu alan şirkettir, ancak riski taşıyan kullanıcıdır. Kullanıcı farkında olmadan borç veren taraf konumuna düşer. Borç verenin borç verdiğinden haberdar olmaması, deneyim borcunu teknik borçtan daha tehlikeli kılar.

Üretim Derinliği

Bir ürünün ne kadar derin üretilmesi gerektiğinin tek bir cevabı yoktur; ancak derinliği belirleyen dört soru vardır:

1. **Hatanın bedeli ne kadar büyüktür?** Bir blog sayfasının bozulması ile şifrelerin saklandığı bir sistemin bozulması aynı bedeli taşımaz. Bedel büyüdükçe derinlik artmalıdır.

2. **Bedeli kim öder?** Hata yalnızca üreticiye zarar veriyorsa ne kadar risk alınacağı onun kararıdır. Zarar kullanıcıya ya da üçüncü kişilere gidiyorsa üretici daha derine gitmelidir, çünkü riski alan ile bedeli ödeyen aynı değildir.

3. **Hata geri alınabilir mi?** Yanlış bir buton rengi ertesi gün düzeltilir; sızan bir anahtar geri toplanamaz. Geri alınamayan yerler en derin üretilmesi gereken yerlerdir.

4. **Kullanıcı bunu kendisi doğrulayabilir mi?** Kullanıcı hızı, tasarımı ve kolaylığı kendisi değerlendirebilir; güvenliği, veri bütünlüğünü ve iç yapıyı değerlendiremez. Kullanıcının doğrulayamadığı her yerde doğrulamayı üretici yapmak zorundadır.

Bu sorular tek bir kuralda birleşir:

> Ürün, görünen yüzeyi kadar değil, hatanın ulaşabileceği derinlik kadar derin üretilmelidir.

Railway örneğinde arayüz ve geliştirici deneyimi yüzeydi; orada hızlı ilerlemek sorun değildi. Ortam değişkenleri deposu ise ürünün en derin noktasıydı: bedeli büyüktü, bedel başkalarına düşüyordu, hata geri alınamıyordu ve kullanıcı bu katmanı kontrol edemiyordu. Dört soru da en derine gidilmesini gerektiriyordu.

Her parçayı en yüksek düzeyde üretmeye çalışmak da doğru değildir; bu zaman ve kaynak israfına yol açar ve ürünün hiç tamamlanamamasıyla sonuçlanabilir. Önemli olan derinliği eşit dağıtmak değil, doğru yere yerleştirmektir.

Bütün bunların bir alt sınırı vardır: olmayan bir nitelik varmış gibi gösterilmemelidir. Güvenliği sınırlı bir ürün kabul edilebilir; güvenliği sınırlı olup çok güvenli görünen bir ürün ise aradaki farkı kullanıcının aleyhine kullanır.

Mühendislikte Kalite Hiyerarşisi ve Standartlar

ISO/IEC 25010 Hiyerarşisi

Mühendislikte kalite kavramları ISO/IEC 25010 standardında bir hiyerarşi içinde tanımlanır. Bu hiyerarşinin üstüne, kalitenin kendi başına amaç olmadığını vurgulamak için değer kavramı konabilir: ürün bir ihtiyacı karşılamak için vardır, kalite bunun ne ölçüde iyi yapıldığının ölçüsüdür.

- Değer
  - Kalite
    - Ürün kalitesi (üreticinin içeriden ölçtüğü)
      - İşlevsel uygunluk
      - Performans verimliliği
      - Uyumluluk
      - Etkileşim yeteneği (önceki adıyla kullanılabilirlik)
      - Güvenilirlik
      - Güvenlik (*security*)
      - Bakım kolaylığı
      - Esneklik (önceki adıyla taşınabilirlik)
      - Emniyet (*safety*)
    - Kullanımda kalite (kullanıcının yaşadığı)
      - Etkinlik
      - Verimlilik
      - Memnuniyet
      - Riskten özgürlük
      - Bağlam kapsamı

Ürün kalitesi listesi standardın 2023 sürümünü, kullanımda kalite listesi ise 2011 sürümünü izler; 2023'te kullanımda kalite modeli ayrı bir standarda (ISO/IEC 25019) taşınmıştır.

Notta tartışılan kavramlar bu hiyerarşide şu yerlere düşer:

- **Doğruluk**: İşlevsel uygunluğun altında, işlevsel doğruluk olarak.
- **Hız**: Performans verimliliğinin altında; standart bunu zaman davranışı olarak adlandırır.
- **Kararlılık**: Güvenilirliğin altında.
- **Okunabilir kod ve testler**: Bakım kolaylığının altında.

Türkçede "güvenlik" kelimesi iki ayrı mühendislik kavramını karşılar. Güvenlik (*security*) kötü niyetli bir tarafa karşı korunmayı, emniyet (*safety*) ise kazaya ve

zarara karşı korunmayı ifade eder. Railway olayı bir güvenlik, fabrika hattındaki çatlak parça ise bir emniyet sorunudur.

Mühendislikte gereksinimler de ikiye ayrılır. İşlevsel gereksinimler ürünün ne yaptığını, işlevsel olmayan gereksinimler ise nasıl yaptığını tanımlar. Hız, güvenlik ve güvenilirlik gibi nitelikler ikinci gruba girer; İngilizcede adlarının çoğu "-ility" ekiyle bittiği için bunlara topluca *ilities* de denir.

ISO/IEC 25010'un Kökeni

ISO/IEC 25010 tek bir kişi ya da şirket tarafından değil, iki uluslararası kuruluşun ortak komitesi tarafından hazırlanmıştır: Uluslararası Standardizasyon Örgütü (ISO) ve Uluslararası Elektroteknik Komisyonu (IEC). Bu iki kuruluşun bilgi teknolojileri için kurduğu ortak teknik komite (JTC 1) altında yazılım ve sistem mühendisliğiyle ilgilenen alt komite (SC 7) standardın hazırlanmasından sorumludur. Komitelerde ulusal standart kuruluşlarından gelen uzmanlar çalışır; Türkiye'yi Türk Standardları Enstitüsü (TSE) temsil eder.

Standardın ilk sürümü 2011'de yayımlanmış, 2023'te güncellenmiştir. 2023 güncellemesinde emniyet ayrı bir nitelik olarak eklenmiş ve bazı nitelik adları değiştirilmiştir.

ISO/IEC 25010, 1991'de yayımlanan ISO/IEC 9126 standardının yerini almıştır. ISO/IEC 9126 da 1970'lerde geliştirilen iki kalite modeline dayanır: ABD Hava Kuvvetleri için hazırlanan McCall modeli (McCall, Richards ve Walters, 1977) ve Boehm modeli (Boehm vd., 1978). Standart, 25000 ile başlayan ve SQuaRE (*Systems and software Quality Requirements and Evaluation*) olarak adlandırılan bir standart ailesinin parçasıdır.

Başarının Kaynağı: Standart mı, Ortam mı

ABD ve İsrail gibi ülkelerdeki şirketlerin başarısı çoğu zaman bilinen ama başkalarının erişemediği standartlara bağlanır. Oysa ISO standartları herkese açıktır ve Türkiye de ISO üyesidir; bu ülkelerdeki şirketlerin elinde gizli bir kalite kitabı bulunmaz.

İlk olarak öncülün kendisi düzeltilmelidir: bu ülkelerde her şirket başarılı olmaz. Kurulan girişimlerin büyük çoğunluğu başarısız olur; Railway ve Equifax da ABD şirketleridir. Görünür olan isimler hayatta kalanlardır; batanlar duyulmadığı için bütün şirketler başarılı görünür. Bu, hayatta kalan yanılgısıdır (*survivorship bias*).

Başarılı şirketlerin arkasında standarttan çok bir ortam bulunur:

- **Sermaye**: Derin bir risk sermayesi piyasası, şirketlerin yıllarca kâr etmeden büyümesine ve görünmeyen işlere yatırım yapacak zaman bulmasına imkân verir.
- **Pazar ölçeği**: Tek bir dil ve tek bir pazarla çok büyük bir müşteri kitlesine ulaşılabilmesi, kaliteye yapılan yatırımın geri dönmesini sağlar.

- **Müşteri baskısı**: Büyük kurumlar bir yazılımı satın almadan önce güvenlik denetimi ister. ABD'de bunun için SOC 2 gibi denetim raporları, kamu işleri için NIST ve FedRAMP gibi çerçeveler kullanılır. Doğrulamayı müşterinin zorunlu kılması, limon piyasası sorununu kısmen çözer.
- **Hukuki bedel**: Dava, ceza ve itibar kaybı, görünmeyen kaliteyi şirket için görünür bir maliyete çevirir.
- **Yetişme yolu**: İsrail'deki güçlü siber güvenlik sektörü büyük ölçüde askerî birimlerde gerçek saldırı ve savunma deneyimi kazanmış mühendislere dayanır.
- **Başarısızlığa tolerans**: Başarısız bir girişim kurmuş olmak çoğu zaman bir kusur değil deneyim olarak görülür; bu, yeniden denemeyi kolaylaştırır.

Standartlar neyin önemli olduğunu söyler; bir şirketin bu önemli şeylere gerçekten yatırım yapıp yapmayacağını ise sermayesi, müşterisi, hukuki ortamı ve ekibi belirler.

Takip Edilmesi Gereken ISO Standartları

Hangi standartların izleneceği şirketin ne ürettiğine göre değişir. Yazılım üreten bir şirket için genel bir sıralama şöyledir:

Temel Standartlar

- **ISO/IEC 27001**: Bilgi güvenliği yönetim sistemi. En sık talep edilen standarttır; kurumsal müşteriler ve Avrupalı alıcılar çoğu zaman bu sertifikayı sorar.
- **ISO 9001**: Genel kalite yönetim sistemi. Yazılıma özgü değildir, süreçlerin düzenli işlediğini gösterir.
- **ISO/IEC 25010**: Kalite modeli. Sertifikası yoktur; ürün tasarlanırken hangi niteliklerin atlandığını kontrol etmek için bir rehber olarak kullanılır.

Ürüne Göre Eklenecekler

- **ISO/IEC 27701**: Kişisel veri işleyen ürünler için gizlilik yönetimi; GDPR ve KVKK uyumunu kolaylaştırır.
- **ISO/IEC 27017 ve 27018**: Bulut hizmetlerinin güvenliği ve bulutta kişisel verinin korunması.
- **ISO 22301**: İş sürekliliği; bir olaydan sonra sistemin ne kadar sürede ayağa kaldırılacağının planlanması. Railway'in iki günlük kilidi bu standardın konusuna girer.
- **ISO/IEC 42001**: Yapay zekâ yönetim sistemi; 2023'te yayımlanan, alandaki ilk uluslararası yönetim sistemi standardı.

Sektöre Özgü Standartlar

- **ISO 26262**: Otomotiv yazılımlarında işlevsel emniyet.
- **IEC 62304**: Tıbbi cihaz yazılımlarının yaşam döngüsü.
- **IEC 62443**: Endüstriyel otomasyon ve kontrol sistemlerinin güvenliği.

Aşamaya Göre Öncelik

- Küçük bir girişim için sertifikaya kaynak ayırmadan önce ISO/IEC 27001'in kontrol listesini ve ISO/IEC 25010'u rehber olarak kullanmak yeterlidir.
- Kurumsal müşteriye satış başladığında ISO/IEC 27001 sertifikası gündeme gelir.
- ABD pazarında ISO sertifikasından çok SOC 2 raporu talep edilir.

Sertifikanın Gerçek Değeri

Sertifika bir güven sinyalidir, güvenliğin kendisi değildir. Bir şirket ISO/IEC 27001 sertifikası alıp yine de sızıntı yaşayabilir; çünkü sertifika çoğu zaman süreçlerin yazılı olduğunu gösterir, her gün uygulandığını değil. Sertifika bir doğrulama türüdür ama tam bir doğrulama değildir. Asıl değeri, şirketi görünmeyen işleri düzenli olarak yapmaya zorlamasındadır.

Bu zorlamanın mekanizması denetimdir: denetçi "bunu yapıyor musunuz" diye sormaz, kanıt ister. Bu nedenle normalde ertelenecek işler takvime ve kayda bağlanır. Başlıca örnekler şunlardır:

1. **İşten ayrılan çalışanın erişiminin kapatılması.** Ayrılan kişinin sunucu ve veritabanı erişimi çoğu zaman unutulur ve hesap aylarca açık kalır. Standart, erişimlerin belirli aralıklarla gözden geçirilmesini ve ayrılan kişinin hesabının kapatıldığının kayda geçirilmesini ister.
2. **Yedeğin geri yüklenebildiğinin test edilmesi.** Düzenli yedek alan bir şirket, yedeği hiç geri yüklemediyse felaket günü yedeğin bozuk ya da eksik olduğunu öğrenebilir. Standart yedeğin alınmasını değil, geri yüklenebildiğinin düzenli olarak sınanmasını ister.
3. **Anahtar envanterinin tutulması.** Railway olayında bütün kullanıcılar anahtarlarını yenilemek zorunda kaldı. Hangi anahtarın hangi serviste kullanıldığının listesini tutan bir şirket bu işi birkaç saatte tamamlar; listesi olmayan şirket ise günlerce arama yapar.
4. **Olay müdahale planının önceden yazılması.** Bir sızıntıda kimin kimi arayacağı ve müşteriye ne zaman, nasıl bilgi verileceği olay anında düşünülemez. Standart bu planın önceden yazılmasını ve tatbikatla denenmesini ister. Railway'in güvenlik uyarısının saatlerce gecikmesi bu planın eksik kaldığı noktaya işaret eder.

5. **Tedarikçilerin değerlendirilmesi.** Kodun, verinin ve e-postanın tutulduğu her dış hizmet bir risktir. Standart bu hizmetlerin güvenliğinin değerlendirilmesini ve kaydının tutulmasını ister.

6. **Kayıtların yeterince uzun saklanması.** Bir saldırı fark edildiğinde ilk iş geriye dönük kayıtları incelemektir. Kayıtlar yalnızca iki gün tutuluyorsa iki hafta önce başlamış bir saldırının izi silinmiş olur. Railway'in ücretsiz ve düşük paketlerinde denetim kayıtlarının 48 saat tutulması olaydan sonra tartışılan konulardan biri olmuştur.

Bu işlerin ortak özelliği, hiçbirinin kullanıcıya görünmemesi ve yapılmadıkları gün hiçbir şeyin bozulmamasıdır. Bu nedenle sürekli ertelenirler. Standart, bu ertelemeyi bir takvime ve bir kanıta bağlar.

ISO Dışında Bilinmesi Gerekenler

Yazılım Geliştirme Alanında

- **OWASP Top 10**: Web uygulamalarındaki en yaygın on güvenlik açığı kategorisi. OWASP (*Open Worldwide Application Security Project*) kâr amacı gütmeyen bir uygulama güvenliği topluluğudur.
- **OWASP API Security Top 10**: Aynı listenin API'ler için hazırlanmış biçimi.
- **OWASP ASVS** (*Application Security Verification Standard*): Bir uygulamanın güvenliğini madde madde sınamak için hazırlanmış doğrulama standardı; dörtlü modeldeki doğrulama katmanının pratik bir karşılığı.
- **CWE Top 25**: En tehlikeli yazılım zayıflıklarının listesi; CWE (*Common Weakness Enumeration*) zayıflık türlerine ortak adlar verir.
- **NIST SSDF** (*Secure Software Development Framework*, SP 800-218): ABD Ulusal Standartlar ve Teknoloji Enstitüsü'nün güvenli yazılım geliştirme çerçevesi (NIST, 2022).
- **SLSA ve SBOM**: Yazılım tedarik zinciri güvenliği. SLSA (*Supply-chain Levels for Software Artifacts*) build sürecinin bütünlüğünü, SBOM (*Software Bill of Materials*) bir yazılımın hangi bileşenlerden oluştuğunu belgeler. Railway olayının build altyapısından başlaması bu alanın önemini gösterir.
- **CIS Benchmarks**: Sunucu, veritabanı ve bulut hesaplarını güvenli yapılandırmak için hazırlanmış kontrol listeleri.
- **SRE yaklaşımı**: Google'ın site güvenilirlik mühendisliği (*Site Reliability Engineering*) yaklaşımı, güvenilirliği hizmet düzeyi hedefleri (*Service Level Objective*, SLO) ve hata bütçesi (*error budget*) gibi kavramlarla ölçer (Beyer vd., 2016). Kullanımda kalitenin mühendislikteki en somut karşılıklarından biridir.

- **DORA metrikleri**: Bir ekibin yazılım teslim performansını dağıtım sıklığı, değişiklik teslim süresi, değişiklik hata oranı ve hizmeti yeniden ayağa kaldırma süresi üzerinden ölçen dört ölçüt (Forsgren, Humble ve Kim, 2018).
- **Suçlamasız olay sonrası raporu** (*blameless postmortem*): Bir sorundan sonra suçlu aramadan neyin neden bozulduğunun yazıya geçirilmesi.
- **SOC 2**: ABD'de yazılım şirketlerinden en sık istenen güvenlik denetim raporu.
- **GDPR ve KVKK**: Avrupa Birliği ve Türkiye'nin kişisel veri koruma düzenlemeleri.
- **AB Siber Dayanıklılık Yasası**: Avrupa'da satılan dijital ürünler için güvenlik yükümlülükleri getirir; bazı bildirim yükümlülükleri 2026'da, asıl yükümlülükler 2027'de yürürlüğe girer.
- **AB Yapay Zekâ Yasası**: Yapay zekâ ürünleri için risk temelli kurallar.

Bir geliştirici için verimli bir öğrenme sırası şöyledir: önce OWASP Top 10 ve API Security Top 10, ardından SRE'deki SLO fikri, ardından NIST SSDF. Bunlar günlük işe doğrudan yansır. SOC 2 ve yasal düzenlemeler daha çok şirket düzeyindeki konulardır, ancak ne istediklerini bilmek geliştiricinin işini kolaylaştırır.

Genel Alanda

Yazılımla sınırlı olmayan bir bakışla ISO'nun dışında dört grup bilinmelidir.

1. **Diğer standart kuruluşları**: IEC (elektrik ve elektronik), ITU (telekomünikasyon), IEEE (mühendislik standartları; Wi-Fi bir IEEE standardıdır, 802.11), IETF ve W3C (internet ve web), CEN, CENELEC ve ETSI (Avrupa standartları; "EN" ile başlayan normlar), ulusal kuruluşlar (ABD'de ANSI ve NIST, Almanya'da DIN, İngiltere'de BSI, Türkiye'de TSE).
2. **Çalışma yaklaşımları**: Deming'in planla-uygula-kontrol et-düzelt döngüsü (PDCA) kalite düşüncesinin temelidir (Deming, 1986). Toyota üretim sistemi ve yalın üretim (*lean*) israfı azaltmayı ve hatayı kaynağında yakalamayı hedefler (Ohno, 1988). Kaizen küçük ama sürekli iyileştirmeyi, Altı Sigma hatanın istatistikle ölçülüp azaltılmasını, poka-yoke ise hatayı yapılamaz kılan tasarımı ifade eder; bir fişin prize yalnızca doğru yönde girmesi buna örnektir.
3. **Risk ve emniyet yöntemleri**: Hata türleri ve etkileri analizi (*Failure Mode and Effects Analysis*, FMEA) bir sistemde neyin nasıl bozulabileceğini ve sonuçlarını önceden listeler. HAZOP (*Hazard and Operability Study*) özellikle süreç tesislerinde "bu süreç ters giderse ne olur" sorusunu sistematik biçimde sorar. Beş neden (*5 Whys*) tekniği bir sorunda art arda "neden" sorarak kök nedene inmeyi hedefler.

4. **Zorunlu düzenlemeler ve işaretler**: Standartlar çoğu zaman isteğe bağlıdır; bazı alanlarda devlet bunları zorunlu kılar. CE işareti Avrupa'da satılan bir ürünün temel güvenlik gerekliliklerine uyduğunu gösterir; UL ABD'de elektrikli ürünler için güvenlik onayıdır; ilaç ve gıdada FDA, havacılıkta FAA ve EASA gibi sektör kurumları vardır.

Dörtlü modelle düşünüldüğünde bu gruplar doğrulama katmanının farklı araçlarıdır: standart kuruluşları neyin doğru olduğunu tanımlar, çalışma yaklaşımları doğrunun her gün üretilmesini sağlar, risk yöntemleri hatayı gerçekleşmeden bulur, yasalar doğrulamayı herkes için zorunlu kılar. Diğerlerinin çoğu Deming'in döngüsü ve Toyota üretim sistemi üzerine kurulu olduğu için başlangıç noktası olarak bu ikisi uygundur.

Deneyim Yanılsamasından Kurtulma

Bir Şeyde Sorun Olup Olmadığını Anlamak

Bir şeyin gerçekte sorunlu olup olmadığını deneyimin yanıltıcılığından bağımsız biçimde anlamak için şu sorular kullanılabilir:

1. **His mi, sonuç mu değerlendiriliyor?** Bir şeyin nasıl hissettirdiği değil, zaman içinde ne ürettiği izlenmelidir: bir hekimin konuşması değil tedavisinin sonucu, bir şirketin sunumu değil geçmiş kaydı.

2. **Zor bir anda nasıl davranıyor?** İşler iyi giderken sorunlar görünmez. Bir aksaklık, kriz ya da baskı anı gerçek niteliği ortaya çıkarır.

3. **Hatalarını nasıl anlatıyor?** Hiç hatası görünmeyen bir şeyden şüphe edilmelidir. Asıl soru hataların açıkça kabul edilip edilmediğidir; hatasını gizleyen sistem sessiz hata üretir.

4. **Bilgiyi kim veriyor?** Bir şeyin iyi olduğunu söyleyen kişi onu satıyor olabilir. Teşviki farklı, bağımsız bir kaynağın görüşü de alınmalıdır.

5. **Karşı taraf neyle ödüllendiriliyor?** Görünüşle ödüllendirilen görünüşü, gerçek sonuçla ödüllendirilen sonucu iyileştirir. Teşvik bilindiğinde davranış öngörülebilir.

6. **Görünmeyen ne var?** Görünen yüzeyin altında ne bulunduğu, bunun kontrol edilip edilemediği ve kontrol edilemiyorsa kimin kontrol ettiği sorulmalıdır. Kimsenin kontrol etmediği yer en riskli yerdir.

7. **Küçük bir deneme yapılabilir mi?** Büyük bir karardan önce küçük bir sınama yapılmalıdır: yedeği gerçekten geri yüklemek, ürünü küçük bir işte denemek, bir iddiayı bizzat kontrol etmek.

8. **Fazla kolay ve fazla iyi mi geliyor?** Akıcılık bir uyarı işareti olabilir. Fazla pürüzsüz ve fazla ikna edici gelen bir şey, durup soru sorulması gereken andır. His kanıt olarak değil, bir veri olarak ele alınmalıdır.

Özetle bir şeyin nasıl hissettirdiğine değil, zor anda ne yaptığına, hatalarını nasıl anlattığına ve kontrol edilebilir olup olmadığına bakılmalıdır.

Duygu Farkındalığının Sınırı

Bu yaklaşım ilk bakışta "duygularını fark et, davranışlarına yön ver" biçimindeki bilinen öğütle benzerlik taşır. Bilişsel davranışçı terapideki "her düşünce bir gerçek değildir" ilkesi de aynı ortak noktaya sahiptir: bir hissi fark edip ona hemen inanmamak.

Ancak duygu farkındalığı tek başına yetmez, çünkü akıcılık etkisi gibi yanılgılar çoğunlukla fark edilmeden çalışır. Bir yanılgıyı bilmek kişiyi ondan korumaz. İnsanların başkalarındaki yanılgıları kolayca görüp kendilerindekini göremedikleri,

yanılgı kör noktası (*bias blind spot*) adıyla gösterilmiştir (Pronin, Lin ve Ross, 2002). Akıl, kendi kendini denetlemekte zayıftır.

Bu nedenle çözümün önemli bir kısmı içeride değil dışarıdadır. Önceki listedeki soruların çoğu (sonuca bakmak, zor anı gözlemek, bağımsız kaynağa başvurmak, küçük deneme yapmak) duyguyu yönetmekle değil, onu kişinin dışındaki bir şeyle karşılaştırmakla ilgilidir.

Havacılık bunun tipik örneğidir. Deneyimli bir pilot da kalkıştan önce kontrol listesini uygular; çünkü liste pilotun o anki hissine bağlı değildir. Cerrahide Dünya Sağlık Örgütü'nün güvenli cerrahi kontrol listesi kullanılmaya başlandığında komplikasyon ve ölüm oranlarının belirgin biçimde azaldığı gösterilmiştir (Haynes vd., 2009; Gawande, 2009). Cerrahlar kendilerini zaten dikkatli hissediyordu, ancak his yetmiyordu.

Fark şöyle özetlenebilir: duygu farkındalığı kişinin kendini düzeltmesini hedefler; doğrulama ise kişinin kendine güvenmek zorunda kalmaması için dışarıda bir yapı kurar.

Duygunun Yetmediği Yerde Yapı

Duygunun yetmediği yerde, kişinin o anki hissine bağlı olmadan çalışan yapılar gerekir:

1. **Önceden verilmiş kararlar.** Odysseus, Sirenlerin şarkısına dayanamayacağını bildiği için kendini önceden geminin direğine bağlatır; karar his ortaya çıkmadan verilmiştir. Gündelik karşılığı "şu koşulda şunu yaparım" kuralını önceden koymaktır: hiçbir sözleşmeyi bir gece beklemeden imzalamamak gibi.

2. **Kontrol listeleri.** Kişi kendini ne kadar emin hissederse hissetsin adımlar sırayla uygulanır; liste hafızaya ve hisse dayanmayı gereksiz kılar.

3. **Başka gözler.** İnsan kendi hatasını görmekte zorlanır, başkasınınkini kolayca görür. Bankalardaki çift onay, yazılımdaki kod incelemesi ve tıptaki ikinci görüş bu ilkeye dayanır.

4. **Ölçüm ve kayıt.** His yerine sayı kullanılır. "Bu ay iyi geçti gibi" yerine gerçekte ne olduğunun yazılması, hafızanın ve duygunun çarpıtmasına karşı korur.

5. **Sonucun görülmesi.** Yapılan işin sonucu düzenli olarak görülmezse his düzelmez. Deming'in döngüsü bu noktada devreye girer: planlamak, uygulamak, sonuca bakmak, düzeltmek.

6. **Ortam tasarımı.** En güçlü yöntem hatayı zorlaştırıp doğruyu kolaylaştırmaktır. Poka-yoke örneğinde olduğu gibi, fiş prize yanlış yönde hiç girmiyorsa dikkatli olmaya gerek kalmaz.

Bu yapılar duyguyu yok saymak için değildir. Duygu değerli bir bilgidir; bir şeyin "yanlış geldiğini" hissetmek çoğu zaman doğru bir uyarıdır. Yapılar

yalnızca hissin tek başına karar verici olmamasını sağlar. Amaç duyguyu kontrol etmeye çalışmak değil, duyguya bağımlılığı azaltan bir düzen kurmaktır.

Kişisel Sistem Kurmak

Bir kurumda bu tür yapılar yoksa boşluk ya hiç doldurulmaz ya da birey tarafından doldurulur. Birey bunun için kendini düzenli olarak uyaracak küçük bir sistem kurabilir:

1. **Kişisel kontrol listeleri.** Sık yapılan işler için kısa listeler. Örneğin bir değişikliği yayına almadan önce: testlerin geçtiği, gizli bilginin kodda kalmadığı ve geri alma yolunun bulunduğu kontrol edilir.

2. **Takvime bağlı hatırlatıcılar.** Görünmeyen işler kendiliğinden hatırlanmaz. Erişimlerin aylık gözden geçirilmesi, bir yedeğin üç ayda bir geri yüklenmesi ve anahtar envanterinin üç ayda bir kontrol edilmesi takvime bağlanabilir.

3. **Makineye bırakılan denetim.** En güvenilir hatırlatıcı unutmayan bir makinedir: koddaki gizli bilgileri yakalayan tarayıcılar, eskiyen bağımlılıkları bildiren araçlar, testler geçmeden yayına izin vermeyen kurallar.

4. **Hata defteri.** Bir şey ters gittiğinde ne beklendiği, ne olduğu ve bir sonraki sefere neyin değiştirileceği kısaca yazılır. Zamanla bu defter kişisel kontrol listelerinin kaynağı olur.

5. **Başka bir göz.** Resmî bir inceleme süreci olmasa bile önemli bir değişiklikte bir meslektaştan görüş istemek.

Bu tür bir sistem için üç uyarı geçerlidir. Birincisi, küçük başlanmalıdır; her şey birden kurulmaya çalışılırsa sistem kısa sürede yüke dönüşür ve bırakılır. İkincisi, kişisel sistemin bir sınırı vardır; birey yalnızca kendi işini koruyabilir, kurumun geri kalanındaki boşluklar açık kalır. Üçüncüsü, kurulan sistem görünür kılınmalıdır; "yayından önce şunlara bakıyorum, işe yarıyor" biçiminde paylaşılan kişisel bir düzen çoğu zaman kurumsal sistemlerin başlangıç noktası olur. Birçok standart da birinin kendi düzeninin zamanla yayılmasıyla doğmuştur.

Yaratıcılık, Deneme Maliyeti ve Yenilik

Yalın İyileştirme ve Sıçrama

Bir icat ortaya çıktıktan sonra çoğunlukla yalın üretim mantığıyla adım adım geliştirilir. Otomobil bunun tipik örneğidir: on yıllar boyunca küçük iyileştirmelerle olgunlaşmıştır. Ancak zaman zaman bu çizginin dışına çıkan bir sıçrama yaşanır.

Güncel bir örnek Tesla'nın yeni Roadster modelidir. Haberlere göre araç 15 Ekim 2026'da SpaceX'in Teksas'taki test tesisinde tanıtılmış; gösteride bir rampadan fırlayarak kısa bir süre havada kalmış, takla atıp tekerleklerinin üzerine inmiştir. Musk aracın on itki memesi ve yüksek basınçlı hava tanklarıyla donatıldığını söylemiş; gösteride sürücü bulunmamış ve üretimin 2028'de başlaması planlanmıştır (AFP, 2026; Isidore, 2026). CNN, Musk'ın geçmişte verdiği takvimleri sık sık yıllarca kaçırdığını hatırlatmıştır. Elde bulunan şey bu aşamada bir üründen çok bir gösteridir.

Deneme Maliyeti

Bir sıçramayı belirleyen şey çoğu zaman zekâdan çok bir denemenin maliyetidir. Deneme ucuz olduğunda çok sayıda şey denenir ve uçuk fikirler de bu kümeye girer. Deneme pahalı olduğunda yalnızca güvenli olan denenir. Yalın üretim bilinen bir şeyi adım adım iyileştirmek için çok uygundur, ancak bilinmeyen bir yere sıçramak için tasarlanmamıştır.

Çizim bu açıdan güçlü bir araçtır: denemesi neredeyse bedavadır ve hayal gücünü sınırlamaz. Bir mimarın çok uçuk biçimleri deneyebilmesi buna dayanır; yanlış bir çizim kimseye zarar vermez. Ancak mimarın çizdiği uçuk tasarımların çoğu hiç inşa edilmez. Zaha Hadid'in birçok tasarımı, onları hesaplayıp inşa edilebilir kılacak bilgisayar programları gelişene kadar uzun süre kâğıt üzerinde kalmıştır. Dörtlü modelle ifade edildiğinde:

- **Çizim**: Hayal katmanı; maliyeti çok düşüktür.
- **Bina**: Gerçek katman; maliyeti çok yüksektir.
- **Statik hesap ve mühendislik**: Doğrulama; iki katmanı birbirine bağlar.

Mimar hayalde özgürdür, çünkü gerçekle arasında güçlü bir doğrulama katmanı bulunur.

Otomotiv üreticisinin denemesi ise kâğıtta değil yoldadır. Üretim derinliğini belirleyen dört sorunun hepsi ona temkin önerir: hatanın bedeli büyüktür (insanlar ölebilir), bedeli başkaları öder (sürücüler ve yayalar), hata geri alınamaz (milyonlarca araç yola çıktıktan sonra) ve her deneme pahalıdır (kalıplar, fabrikalar, çarpışma testleri, onay süreçleri). Bu koşullarda küçük adımlarla ilerlemek akılcıdır.

Sıçramayı Mümkün Kılan Koşullar

1. **Denemenin ucuzlaması.** Simülasyon, üç boyutlu yazıcılar ve yazılım, pahalı bir denemeyi çizime yaklaşan bir maliyete indirir. SpaceX'in test roketlerini sık sık patlatarak öğrenmesi bu ilkeye dayanır: patlayan bir test roketi, uçuşta patlayan bir yolcu roketinden çok daha ucuzdur.

2. **Başka bir alandan aktarım.** Roadster'a roket teknolojisi taşınmıştır. Birçok sıçrama yeni bir icattan değil, bir alanda bilinen bir şeyin başka bir alana aktarılmasından doğar.

3. **Kenarda deneme.** Roadster az sayıda üretilecek pahalı bir spor otomobildir ve Musk'ın kendi ifadesiyle emniyet için optimize edilmiş bir araç değildir. Riskli fikir şirketin ana ürününde değil, kenardaki küçük bir üründe denenir; ana üretim yalın mantıkla sürer.

4. **Başarısızlığı karşılayacak sermaye.** Uçuk denemelerin çoğu başarısız olur. Bu maliyeti karşılayacak kaynak yoksa kimse denemez.

Terim konusunda bir ayrım gereklidir. Yıkıcı inovasyon (*disruptive innovation*) terimini ortaya atan Clayton Christensen onu özel bir anlamda kullanır: daha basit ve daha ucuz bir ürünün pazarın alt ucundan gelerek yerleşik şirketleri yerinden etmesi (Christensen, 1997). Uçan bir spor otomobil bu anlamda yıkıcı değil, radikal bir yeniliktir. Sıçramayı neyin mümkün kıldığı sorusu ise her iki tür için de geçerlidir.

Çizim yıkıcı inovasyonun kendisi değil, onun en ucuz laboratuvarıdır. Sıçrama, hayal gücünün serbest olduğu ucuz bir alan ile gerçeğin acımasız olduğu pahalı bir alan arasında sağlam bir köprü kurulabildiğinde gerçekleşir; bu köprü de doğrulamadır.

Deneyim Prototipleme

Bir ürünü üretmeden onun deneyimini yaşatmanın yöntemleri deneyim prototipleme (*experience prototyping*) adıyla bilinir. Buchenau ve Fulton Suri bu kavramı, ürün henüz yokken onu kullanmanın nasıl bir şey olduğunu yaşatan her türlü temsil olarak tanımlar (Buchenau ve Fulton Suri, 2000). Başlıca yöntemler şunlardır:

1. **Simülatör ve sanal gerçeklik.** Otomotiv şirketleri yeni bir aracı üretmeden önce sürüş simülatörlerinde ve sanal gerçeklik ortamında dener; kokpitin içine oturup çevreye bakmak mümkündür.

2. **Maket.** Köpükten, ahşaptan ya da kilden yapılmış tam boyutlu modeller. Otomotivde kil modeller hâlâ kullanılır; kapıyı açmak, koltuğa oturmak ve direksiyonu tutmak motor olmadan da denenebilir.

3. **Perde arkasındaki insan** (*Wizard of Oz*). Sistem otomatikmiş gibi görünür, ancak arka planda bir insan tarafından yönetilir. 1980'lerde konuşmayı yazıya çeviren bir bilgisayar fikri, kullanıcının sözlerini gizlice

bir daktilografın yazdığı bir düzenekle sınanmıştır (Gould, Conti ve Hovanyecz, 1983).

4. **Hikâye ve video.** Ürünün bir hikâye ya da kısa film olarak anlatılması. Apple'ın 1987 tarihli "Knowledge Navigator" videosu, o sırada var olmayan konuşan ve akıllı bir dijital asistanı göstermiştir.

5. **Benzer deneyimlerin ödünç alınması.** Uçan bir otomobilin hissinin bir kısmını hız trenleri, paraşüt simülatörleri ve rüzgâr tünelleri verir; deneyim parçalarına ayrılıp her parça var olan bir şeyle sınanabilir.

6. **Canlandırma** (*bodystorming*). Katılımcıların ürünü kullanıyormuş gibi davranması; kartondan bir düzeneğin içine oturup nereye bakılacağının, neyden korkulacağının ve ne isteneceğinin konuşulması.

Roadster gösterisinin kendisi de bir deneyim prototipidir: içinde sürücü bulunmayan ve rampadan fırlayan araç bir ürün değil, kamuoyunun fikre nasıl tepki verdiğini ölçen bir temsildir.

Deneyim prototipi yalnızca deneyim katmanını sınar; doğruluğu ve sonucu sınamaz. Bir şeyin iyi hissettirdiğini gösterir, ancak yapılabilir, güvenli ya da kârlı olup olmadığını göstermez. Gösteriyi ürünle karıştırmak, deneyim borcunun en hızlı yoludur. Doğru sıra şöyledir: önce deneyim ucuz biçimde denenir ve gerçekten istenen bir şey olup olmadığı anlaşılır; ardından pahalı olan gerçek katmana doğrulama ile adım adım geçilir.

El Çizimi ve Yapay Zekâ ile Konsept Video

El ile çizilmiş bir taslaktan yapay zekâ ile konsept video üretmek, deneyim prototiplemenin güncel bir biçimidir. 1987'de bir konsept videosu için büyük bir ekip ve bütçe gerekiyordu; bugün benzer bir video bir taslaktan kısa sürede üretilebilir.

Yöntemin güçlü yanları şunlardır:

- Maliyeti çizime yakındır.
- Hızlıdır; aynı fikrin pek çok farklı biçimi kısa sürede görülebilir.
- Paylaşılabilir; bir taslağı anlatmak zordur, bir video ise herkese benzer bir his verir ve tepkilerin ölçülmesini kolaylaştırır.
- Hayal gücünü genişletir; çizilen şeyi hareket hâlinde görmek yeni fikirler doğurur.

Yöntemin riski, akıllı bir sohbet cevabının riskiyle aynıdır. Yapay zekâ videosu çok akıcıdır, çok gerçek görünür ve bu nedenle güçlü bir güven sinyali üretir. Ancak yapay zekâ fiziği hesaplamaz; küçük kanatlarla bir aracın gerçekten uçup uçamayacağını kontrol etmez, yalnızca uçuyormuş gibi gösterir. Böylece elde iki şey bulunur: kaba ama dürüst bir el çizimi ve parlak ama doğrulanmamış

bir film. Risk, ikincisinin birincisinden daha gerçek hissettirmesi ve hem üreticinin hem izleyicinin fikrin yapılabilir olduğuna inanmaya başlamasıdır.

Yöntem şu ilkelerle kullanılmalıdır:

1. Video yapılabilirliği değil hissi sınamak için kullanılır; "insanlar bunu ister mi" sorusunu yanıtlar, "bu yapılabilir mi" sorusunu yanıtlamaz.
2. Konsept olduğu açıkça belirtilir. Henüz var olmayan bir ürünü gerçek bir reklam gibi sunmak yanıltıcı reklam sayılabilir.
3. Videonun ardından "bunun gerçek olması için neyin doğru olması gerekir" sorusu sorulur; bu soru hayal katmanından gerçek katmana geçişin ilk adımıdır.

Disney, Pixar ve Apple

Bu kurumların en büyük becerisi çizim değildir. Ortak noktaları, ucuz bir alanda çok sayıda deneme yapmak ve pahalı aşamaya geçmeden önce denemeleri sert biçimde eleştirmektir.

Disney

Bir filmi sahne sahne çizip duvara asma yöntemi olan storyboard, 1930'larda Disney stüdyosunda gelişmiştir. Animasyon çok pahalı olduğu için storyboard, bir filmi pahalı biçimde üretmeden önce ucuz biçimde denemeyi mümkün kılmıştır.

Walt Disney'in çalışma biçimi Robert Dilts tarafından üç rol üzerinden modellenmiştir (Dilts, 1994):

- **Hayalci**: Sınırsız düşünür; "ya şöyle olsaydı" sorusunu sorar.
- **Gerçekçi**: "Bu nasıl yapılır" sorusunu sorar.
- **Eleştirmen**: "Burada ne ters gidebilir" sorusunu sorar.

Bu üç rol dörtlü modelle örtüşür: hayalci deneyimi kurar, gerçekçi doğruluğu düşünür, eleştirmen doğrulamayı yapar. Önemli olan rollerin aynı anda değil sırayla üstlenilmesidir.

Pixar

Pixar'ın kurucularından Ed Catmull'a göre Pixar filmlerinin hepsi ilk aşamada kötüdür; mesele kötü olandan iyiye nasıl gidileceğidir (Catmull, 2014). Bunun için iki mekanizma kullanılır:

- **Story reel**: Storyboard çizimlerinin sırayla dizilip geçici seslerle bir film gibi oynatılması. Pahalı üç boyutlu üretime geçmeden önce film bu ucuz biçimiyle defalarca izlenir ve değiştirilir; bu bir deneyim prototipidir.
- **Braintrust**: Yönetmenlerden oluşan bir grup yapım aşamasındaki filmi izler ve dürüstçe eleştirir, ancak karar vermez; karar yönetmende kalır.

Catmull ayrıca yeni fikirlerin başlangıçta çirkin olduğunu ve korunmaları gerektiğini vurgular; çok erken eleştirilen fikirler ölür. Dolayısıyla hem eleştiri hem koruma gereklidir.

Apple

Steve Jobs iyi bir çizer ya da tasarımcı değildi; becerisi seçmekti. Jony Ive'ın tasarım stüdyosunda bir ürünün çok sayıda fiziksel modeli yapılır, Jobs bunları dener ve çoğunu reddederdi. Walter Isaacson'un biyografisine göre Jobs bir ürünün tasarımını ileri bir aşamada, beğenmediği için baştan yaptırmıştır (Isaacson, 2011).

Ortak Nokta

Üç kurumda da çizim bir araçtır, amaç değildir. Ortak beceriler şunlardır:

1. Denemeyi ucuzlatmak: storyboard, story reel, fiziksel modeller.
2. Çok sayıda deneme yapmak.
3. Dürüst ve sert bir eleştiri düzeni kurmak.
4. Yeni ve kırılgan fikri çok erken öldürmemek.
5. Pahalı aşamaya ancak bunlardan sonra geçmek.

Uçtan Uca Deneyim: Jobs'un Yöntemi

Jobs deneyimi parça parça değil uçtan uca düşünüyordu; kutunun açılmasından ürünün ilk çalıştırılmasına kadar her şey tek bir deneyimin parçasıydı. Bunun tek bir sırrı yoktu; Isaacson'un anlatımına göre birkaç alışkanlığın birleşimiydi (Isaacson, 2011):

1. **Bütünü tek elde tutmak.** Donanım, yazılım ve daha sonra satış kanalı aynı şirket tarafından yapılmalıydı. Başka şirketler bilgisayarı üretip yazılımı başkasına bırakırken Apple ikisini birlikte tasarladı; ardından iTunes, App Store ve Apple Store mağazalarını ekledi. Bir deneyimin her parçası kontrol edilmeden uçtan uca tasarlanamaz. Bu tercihin karşılığı daha kapalı bir sistemdir.
2. **Az ürün yapmak.** Jobs 1997'de Apple'a döndüğünde şirketin çok sayıda ürününü ev ve profesyonel kullanıcı için birer masaüstü ve birer dizüstü bilgisayardan oluşan dört temel ürüne indirdi. Az ürün, her birinin bütün yolculuğuna dikkat ayırmayı mümkün kıldı.
3. **Tek bir son karar verici.** Her ürünün ayrı bir birim gibi çalıştığı yapı yerine tasarım, mühendislik ve yazılım bölümlerinin birlikte çalıştığı bir yapı kuruldu ve son söz tek bir kişideydi. Bütün parçalar aynı zevkten geçtiği için birbirini tutuyordu. Bu bir güç olduğu kadar bir riskti: her şey bir kişiye bağlıydı.

4. **Deneyimi gerçek boyutta denemek.** Apple Store mağazaları açılmadan önce Jobs ve mağaza sorumlusu Ron Johnson bir depoda tam boyutlu bir deneme mağazası kurdu. Aylarca çalıştıktan sonra ürünleri türlerine göre dizmenin hatalı olduğunu, insanların belirli işler için geldiğini fark ettiler ve mağazayı yapılacak işlere göre yeniden düzenlediler. Bu, tam anlamıyla bir deneyim prototipiydi.

5. **Ambalajı ürünün parçası saymak.** Kutunun açılışı ve içindekilerin hangi sırayla göründüğü ayrı bir tasarım işi olarak ele alındı; kutuyu açmak ürünle ilk karşılaşma olduğu için deneyimin ilk adımı sayıldı.

6. **Görünmeyen yeri de özenli yapmak.** Jobs babasından öğrendiği bir ilkeyi anlatırdı: iyi bir marangoz, kimse görmeyecek olsa da dolabın arka yüzünü de özenle yapar. Bu nedenle ilk Macintosh'un içindeki devre kartının da düzenli görünmesini istedi ve ekip imzalarını kasanın içine kazıdı.

Son madde notun ana ayrımına ilginç bir yanıt verir. Jobs görünmeyen kaliteyi görünen deneyimin bir parçası olarak ele almıştır. Arka yüzü özensiz bir dolap, ön yüzdeki güzelliği de yanıltıcı kılar. Bu yaklaşımda deneyim borcuna yer yoktur, çünkü görünmeyen katman da görünen katmanla aynı özenle üretilir.

Sonuç

Güvenliği ve kaliteyi deneyimin alt başlıkları olarak görmek kullanıcı açısından doğrudur ve kullanılabilir güvenlik ile ISO/IEC 25010'daki kullanımda kalite modeli bu bakışı destekler. Ancak bu bakış yalnızca deneyimi yaşayan aktörler genişletildiğinde tutarlı kalır. Kullanıcıya görünmeyen parçalar geliştirici, şirket ve toplum tarafından yaşanır; ISO/IEC 25010'un ürün kalitesini kullanımda kaliteden ayırması da bu ayrımın standartlaşmış hâlidir.

Deneyimi her şeyin üst kavramı yapmak ise bir sınırda çöker. Her şey deneyimse "doğru hissettiren ama yanlış olan" bir şeyden söz edilemez ve yanılgı fark edilemez hâle gelir. Deneyim, doğruluk, sonuç ve doğrulama ayrımı bu nedenle bir lüks değil, yanılabilirliği kabul etmenin koşuludur. Bu ayrımın pratik karşılığı şudur: bir sistemin değerlendirilmesinde güven hissi ile güvenilirlik ayrı ayrı sorulmalı ve aradaki bağ ancak bir doğrulama mekanizmasıyla kurulmalıdır.

Akıcılığın bilgiden bağımsız biçimde üretilebilir hâle gelmesi, insan sezgisinin dayandığı eski bir bağı koparmıştır. Bu durum yalnızca dil modellerini değil, parlak arayüzleri, etkileyici gösterileri ve yapay zekâ ile üretilmiş konsept videolarını da kapsar. Hepsi aynı riski taşır: deneyim katmanı, gerçek katmanın taşıyabileceğinden fazla güven üretir. Deneyim borcu kavramı bu riskin muhasebesini tutar ve borç verenin, yani kullanıcının, çoğu zaman borç verdiğinden habersiz olduğunu görünür kılar.

Çerçevenin sınırlılıkları da vardır. Müzik ve sanat gibi alanlarda deneyimin kendisi amaç olduğu için doğrulama katmanının anlamı zayıflar; matematikte ise deneyim katmanı neredeyse hiç sayılmaz. Aşk gibi alanlarda doğrulamanın tek aracı zamandır ve önceden kurulabilecek bir yapıya dönüştürülemez. Ayrıca doğrulamanın kendisi de bir güven sinyaline dönüşebilir: sertifikalar, denetim raporları ve kontrol listeleri gerçekten uygulanmadan yalnızca var olduklarında, deneyim borcunun yeni bir biçimini üretir.

Açık kalan sorular şunlardır: Doğrulamanın maliyeti hangi noktada denemenin kendisinden pahalı hâle gelir ve yeniliği boğar? Deneyim prototiplerinin ürettiği güven, gerçek katman henüz kurulmamışken nasıl ölçülü tutulabilir? Doğrulamayı müşterinin yapamadığı piyasalarda bu yükü kim üstlenmelidir: üretici, düzenleyici mi, yoksa bağımsız üçüncü taraflar mı?

Yaratıcılık alanıyla kurulan bağ, çerçevenin belki de en verimli uzantısıdır. Disney'in storyboard'u, Pixar'ın story reel'i ve Apple'ın deneme mağazası, hayal katmanında ucuz ve çok sayıda deneme yapıp pahalı gerçek katmana ancak sert bir eleştiri ve doğrulama sürecinden sonra geçmenin örnekleridir. Sıçrama, deneyimin doğrulamadan kaçtığı yerde değil, deneyim ile gerçek arasındaki köprünün ucuzlatıldığı yerde gerçekleşir.

Kaynaklar

- AFP. (2026, 17 Ekim). Elon Musk unveils Tesla's 'flying' car. *Citizen Digital*.
- Akerlof, G. A. (1970). The Market for "Lemons": Quality Uncertainty

and the Market Mechanism. *The Quarterly Journal of Economics*, 84(3).

- Beyer, B., Jones, C., Petoff, J. ve Murphy, N. R. (Ed.). (2016). *Site Reliability Engineering: How Google Runs Production Systems*. O'Reilly.
- Boehm, B. W. (1981). *Software Engineering Economics*. Prentice Hall.
- Boehm, B. W., Brown, J. R., Kaspar, H., Lipow, M., MacLeod, G. J. ve Merritt, M. J. (1978). *Characteristics of Software Quality*. North-Holland.
- Buchenau, M. ve Fulton Suri, J. (2000). Experience Prototyping. *Proceedings of the 3rd Conference on Designing Interactive Systems (DIS)*. ACM.
- Catmull, E. (2014). *Creativity, Inc.: Overcoming the Unseen Forces That Stand in the Way of True Inspiration*. Random House.
- Christensen, C. M. (1997). *The Innovator's Dilemma*. Harvard Business School Press.
- Cunningham, W. (1992). The WyCash Portfolio Management System. *OOPSLA '92 Experience Report*.
- Deming, W. E. (1986). *Out of the Crisis*. MIT Press.
- Descartes, R. (1641). *Meditationes de Prima Philosophia*.
- Dewey, J. (1938). *Logic: The Theory of Inquiry*. Henry Holt.
- Dilts, R. (1994). *Strategies of Genius, Volume I*. Meta Publications.
- Forsgren, N., Humble, J. ve Kim, G. (2018). *Accelerate: The Science of Lean Software and DevOps*. IT Revolution.
- Gawande, A. (2009). *The Checklist Manifesto*. Metropolitan Books.
- Gettier, E. L. (1963). Is Justified True Belief Knowledge? *Analysis*, 23(6).
- Goodhart, C. A. E. (1975). Problems of Monetary Management: The U.K. Experience. *Papers in Monetary Economics*. Reserve Bank of Australia.
- Gould, J. D., Conti, J. ve Hovanyecz, T. (1983). Composing Letters with a Simulated Listening Typewriter. *Communications of the ACM*, 26(4).
- Hasher, L., Goldstein, D. ve Toppino, T. (1977). Frequency and the Conference of Referential Validity. *Journal of Verbal Learning and Verbal Behavior*, 16(1).
- Haynes, A. B. vd. (2009). A Surgical Safety Checklist to Reduce Morbidity and Mortality in a Global Population. *The New England Journal of Medicine*, 360(5).

- Isaacson, W. (2011). *Steve Jobs*. Simon & Schuster.
- Isidore, C. (2026, 16 Ekim). Elon Musk unveils the Roadster, a new Tesla he says is a flying car. *CNN*.
- ISO/IEC. (2011). *ISO/IEC 25010:2011 Systems and Software Engineering — Systems and Software Quality Requirements and Evaluation (SQuaRE) — System and Software Quality Models*.
- ISO/IEC. (2023). *ISO/IEC 25010:2023 Systems and Software Engineering — SQuaRE — Product Quality Model*.
- James, W. (1907). *Pragmatism: A New Name for Some Old Ways of Thinking*. Longmans, Green.
- Kalai, A. T., Nachum, O., Vempala, S. S. ve Zhang, E. (2025). Why Language Models Hallucinate. *OpenAI*.
- Kant, I. (1781). *Kritik der reinen Vernunft*.
- Lee, J. D. ve See, K. A. (2004). Trust in Automation: Designing for Appropriate Reliance. *Human Factors*, 46(1).
- McCall, J. A., Richards, P. K. ve Walters, G. F. (1977). *Factors in Software Quality*. Rome Air Development Center, ABD Hava Kuvvetleri.
- Microsoft. (2025). Securing our future: April 2025 progress report on Microsoft's Secure Future Initiative. *Microsoft Security Blog*.
- Microsoft Design. (t.y.). Secure by design: A UX toolkit. *microsoft.design*.
- NIST. (2022). *Secure Software Development Framework (SSDF) Version 1.1*. NIST SP 800-218.
- Ohno, T. (1988). *Toyota Production System: Beyond Large-Scale Production*. Productivity Press.
- O'Neill, O. (2002). *A Question of Trust: The BBC Reith Lectures 2002*. Cambridge University Press.
- Peirce, C. S. (1878). How to Make Our Ideas Clear. *Popular Science Monthly*, 12.
- Popper, K. (1959). *The Logic of Scientific Discovery*. Hutchinson.
- Pronin, E., Lin, D. Y. ve Ross, L. (2002). The Bias Blind Spot: Perceptions of Bias in Self Versus Others. *Personality and Social Psychology Bulletin*, 28(3).
- Railway. (2026). Preliminary Report: Oct 21st Security Incident. *Railway Blog*.

- Reber, R. ve Schwarz, N. (1999). Effects of Perceptual Fluency on Judgments of Truth. *Consciousness and Cognition*, 8(3).
- Weidner, D. (2026). Railway Security Incident: Why Liability Stops at $100. *dennis-weidner.com*.
- Whitten, A. ve Tygar, J. D. (1999). Why Johnny Can't Encrypt: A Usability Evaluation of PGP 5.0. *Proceedings of the 8th USENIX Security Symposium*.